



10. Threat Intelligence

Jin Hong

jin.hong@uwa.edu.au

What is Threat Intel (TI)?

◆ “Details of the motivations, intent, and capabilities of **internal** and **external** threat actors. Threat intelligence includes specifics on the tactics, techniques, and procedures of these adversaries. Threat intelligence's primary purpose is to inform business decisions regarding the risks and implications associated with threats.”

- Forrester

What is Threat Intel (TI)?

“Evidence-based knowledge, including context, mechanisms, indicators, implications and actionable advice about an existing or emerging menace or hazard to assets that can be used to inform decisions regarding the subject’s response to that menace or hazard.”

-Gartner

Threat Intel (TI) =

Strategic:

- ◇ Context
- ◇ Motivations
- ◇ Capabilities
- ◇ Implications
- ◇ Actionable Advice

Operational:

- ◇ Context
- ◇ Mechanisms
- ◇ Indicators
- ◇ Tactics
- ◇ Techniques
- ◇ Procedures

Aspects of Threat Intel

- ◆ Aspects:
 - ◆ Outside
 - ◆ Inside
 - ◆ Inside > Out

Sources of Threat Intel

◆ **Internal:**

- **Logs**
- **Network**
- **Endpoints**
- **Malware Analysis**
- **Phishing Emails**
- **Past incidents**

◆ **Industry Sharing Groups**

- **ISACs (Ag, IT, Financial, etc.)**

◆ **Government**

- **US-CERT, FBI, etc.**

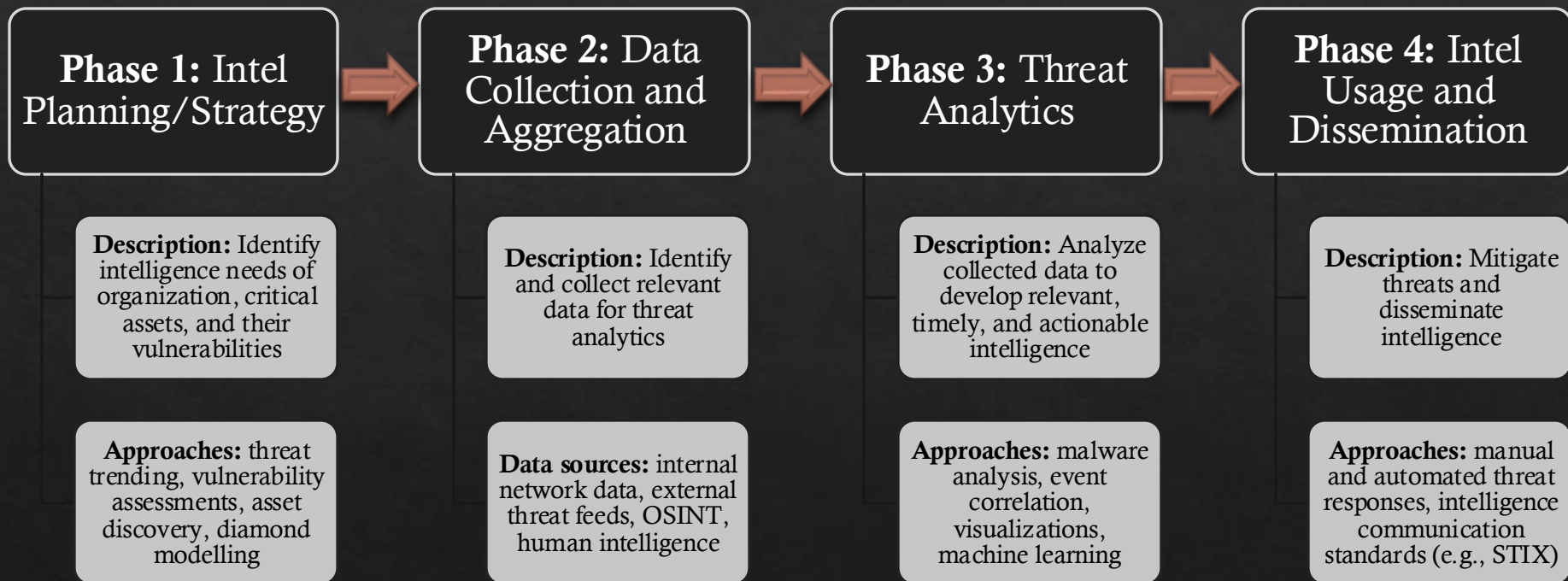
◆ **Org to Org partnerships**

◆ **Vendors (data / analysis)**

◆ **Open Source**

Threat Data or Threat Intel?

TI process



Four phased CTI Lifecycle

Why we need planning and strategy?

- ◇ Bad people are always up to something...
- ◇ Consequences can be dire when cyber attacks are realised
 - ◇ E.g., ransomwares

What are in the underground economy?

UPDATE -- Now offering [Verifone Offline Devices](#)

■ Sell skimmer, pinpad+camera

Hello,

Price for GSM skimmer = **2 000 USD**

+ pinpad (500 USD) + mini-camera (500) = 3 500 USD (assembled)

Decode wav(audio)

Free delivery

Accepted

6-613-622

для серви

1 готовый

е принима

а по всему

на интерес

ли предоп

3-622

about skimm

g

ATM Skimmer

Orbitall **EMV encoder** - EMV encoder

ORBITALL v2.3

ORBITALL v2.3
Corporate ©2016

Configuração / Configuration

Trilha / Track : |

Seleção / Selection

☒ Credito / Credit [ITAU] [SANTA]

☐ Debito / Debit

☐ Credito 128k / Credit 128k

☐ Ticket / Voucher

Gerar / Generate

Limpar / Clean

Orbitall v2.3 - Corporate ©2016

sendspace.com/file/7r4jtl

Good luck !!!

We are glad to serve all your **plastics** needs with JAMES BOND Plastics services.
Estb. and verified since 2012!

-Real signature panel
-Bank Quality plastics
-Uv

Features

PRICES:

BLANKS 101

1-50 = 10\$

51-100 = 9,50\$

101-200 = 9\$

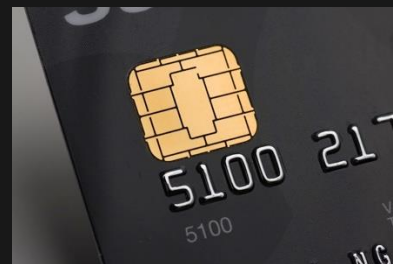
Sold in
batch

BLANKS 201

1-50 = 11\$

51-100 = 10.50\$

Blank Credit/Debit Cards (Plastics)



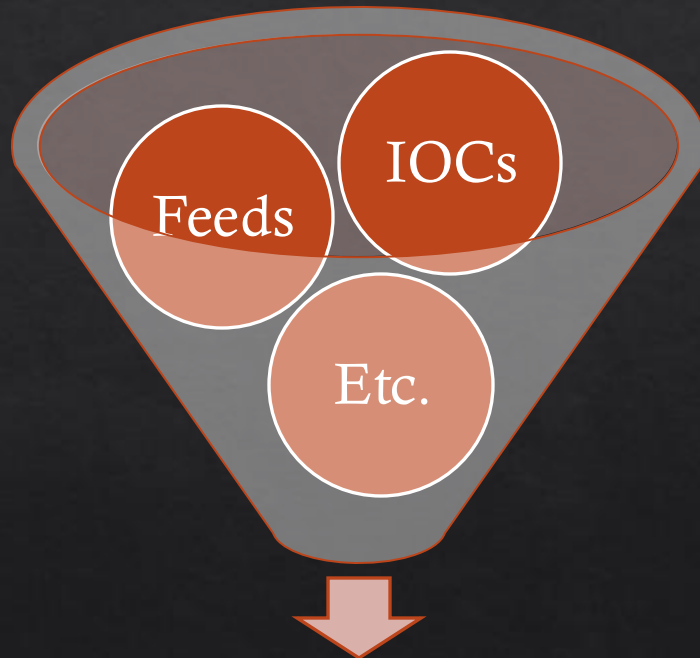
Threat Data

- ◆ Indicators of Compromise

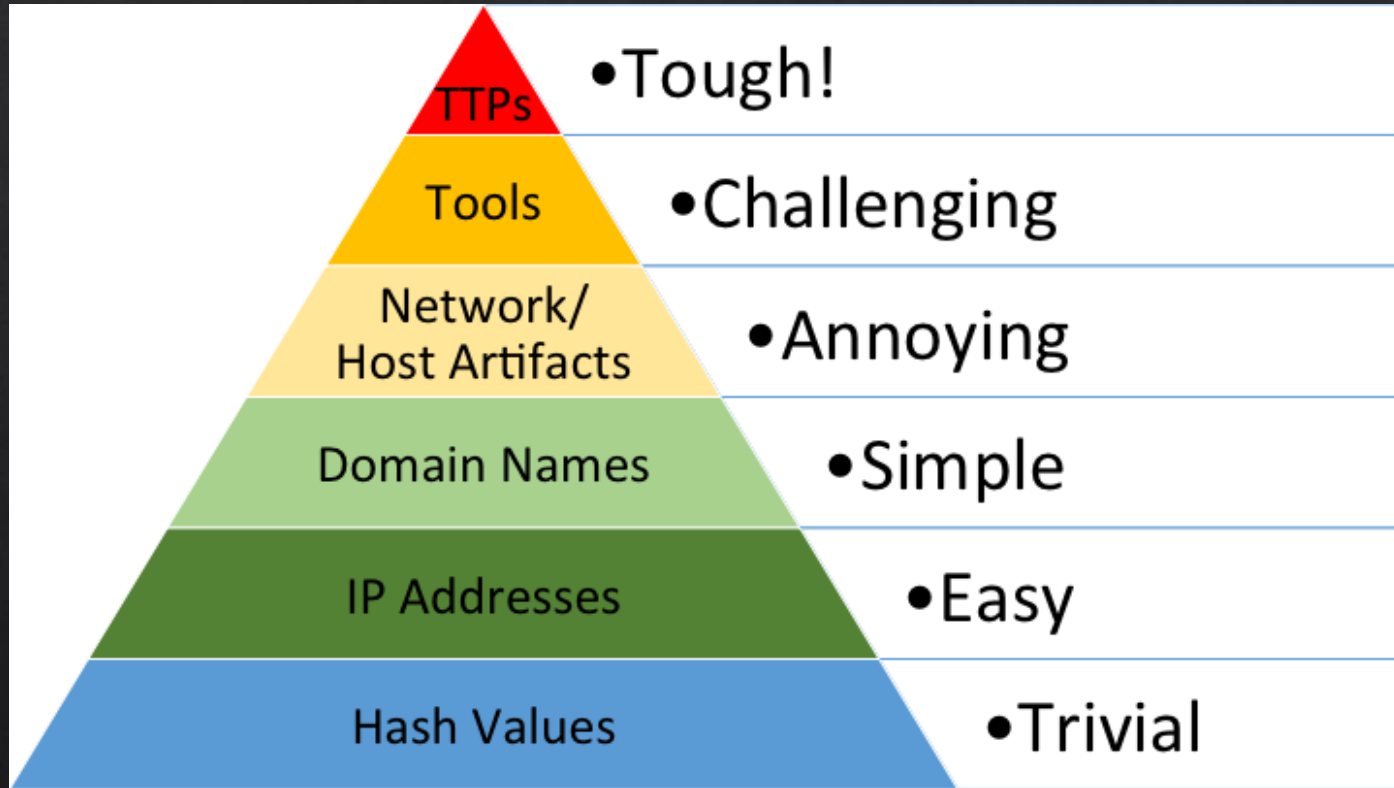
- ◆ IPs
- ◆ Hashes
- ◆ Names
- ◆ Etc..

- ◆ Threat Feeds

- ◆ Etc.



Pyramid of Pain – David Bianco



Collection Challenges

- ◇ Anti-crawling measures
 - ◇ IP address blacklisting
 - ◇ User-agent check
 - ◇ User/password authentication & CAPTCHA validation
 - ◇ Denial of service for too many requests
- ◇ Potential risks of retaliation
 - ◇ Constantly probing underground economy platforms may spook platform owners.
 - ◇ These owners can trace back to us based on network traffic log.

→Need for secure, intelligent collection capabilities

Hacker Community Platforms Overview

Platform	Description	CTI Value
Hacker Forums	Message board allowing members to post messages (archived)	Key threat actor identification; sharing of hacking tools; indication of access to other hacker communities
IRC	Plain-text, instant messaging, communication (not archived)	Sharing of hacking knowledge and potential target; indication of access to other hacker communities
DNMs	Markets on Tor that sell illicit goods via cryptocurrency	Early indicator for breached companies; in-depth understanding of underground economy
Carding Shops	Shops selling stolen credit/debit cards and sensitive data	Monitoring trafficking of internet fraud industry; precaution of breaches before happen

Table 1. Hacker Community Platform Summary

Underlying Mechanism:

- Hackers use forums and/or IRC to freely discuss and share Tools, Techniques, and Processes (TTP).
- Hackers download tools or navigate to DNMs to purchase exploits.
- These tools help hackers conduct cyber-attacks to attain sensitive data such as credit card and SSN.
- Finally, hackers load stolen data to DNMs and/or carding shops for financial gain.

Data Collection Overview: Hacker Forums

The image shows a screenshot of a forum post. On the left is a user profile for 'S.F.C Moderator' with a circular profile picture and statistics: 'Joined: May 8, 2017', 'Messages: 61', and 'Likes Received: 82'. The main post area contains a description of ransomware, a list of three steps (Always on top, Disable Taskbar, Disable key combination), and a code block. Red arrows point from external labels to these elements: 'Poster information' points to the profile, 'Ransomware description' points to the text area, and 'Ransomware code' points to the code block.

Poster information

Ransomware description

Ransomware code

Just give a brief idea about how the Ransomware works around the world, as mentioned earlier, this is simple, so the Bitcoin Option is not used, this is only for sharing the knowledge of java developers
. This is what we are doing in VB.NET. VB.NET is easy to understand because everyone understands it. This concept is simple, let's look at how to code it.

- 1) Always on top
This is where our Ransomware always keeps top on top, that is, above all. This can be used to prevent Taskmanager from being accessed. This can be used because the program can be used to silently run, so if you can disable the Takmgr from the Registry, then you need admin Privilage.
- 2) Disable Taskbar
This will temporarily disable the Taskbar of your computer
- 3) Disable key combination
This will disable the Keybord Shortcut. This is

how we design the Gui. Let
's look at the form's border. Use the one and the scale to maximize. Use the textbox 4 and Button to make the first text box visible from it. Hide the others and
use the code below

```
Code:
Option Strict On
Imports System
Imports System.Security
Imports System.Security.AccessControl
Imports System.Runtime.InteropServices
Imports System.Diagnostics
```

Figure 1. An example of a hacker forum member sharing ransomware code

Data Collection Overview: IRC

```
02:41 < MaLi> https://forum.deathaddict.com/showthread.php?42-Mr-Hands
02:41 <+Meow> Title: Mr. Hands (deathaddict.com: encrypted)
02:42 < MaLi> Nice deflection snowman.
02:42 < MaLi> Stop being a cuck.
02:42 < Animosity> That link tho
02:43 < The_Snowman> .ud cuck
02:43 <+Effexor> Definition: Another name for the great Onision leader of cuckolds.In Cuck fashion, Onision is
02:43 <+Effexor> Example: There goes lord Onision again being the biggest Cuck that ever cucked in the history
02:43 <+Effexor> Tags: cuckold, cucked, cucks, cock, black cucked, cucking, cuckloaded, fuck, shit, agressor
02:43 < GrnMessiah> http://xfrmro77i3lixucja.onion/
```

Figure 2. An example of hackers sharing links containing illegal contents

```
11:59 < Gustav> hack this ip 172.98.79.37
11:59 < Gustav> ddos it
11:59 < Gustav> it's my school
12:00 < Gustav> I love you
```

Figure 3. An example of an IRC user demanding hacking service

Data Collection Overview: DNM

The image displays a screenshot of a product listing page on the Dark Net Market (DNM). The page is divided into two main sections: a grid of product listings on the left and a detailed view of a selected product on the right.

Product Grid (Left):

- Hacking For Newbies:** Price: \$0.0000621, Seller: HappyEyes (5200) (4.79 ★), WW → WW, ESCROW, Order.
- 731986-Hacker's Desk Reference:** Price: \$0.0001864, Seller: color (8000) (4.76 ★), GB → WW, ESCROW, Order.
- Premium Carding Package:** Price: \$0.0003107, Seller: OnePiece (7400) (4.83 ★), PH → WW, ESCROW, Order.
- 6 BITCOIN RANSOMWARE EASY MONEY SYSTEM:** Price: \$0.0003107, Seller: TheWealthMaker (1550) (4.78 ★), WW → WW, ESCROW, Order.
- Go to Windows updates anonymously:** Price: \$0.0000621, Seller: HappyEyes (5200) (4.79 ★), WW → WW, ESCROW, Order.
- HACK ANYONE USING THEIR IP ADDRESS:** Price: \$0.0002486, Seller: TopNotchMoneyMaker (4500) (4.74 ★), WW → WW, ESCROW, Order.
- PayPal - Scam Page (Phishing site) [Looks Great]:** Price: \$0.00031, Seller: MicroDroper (2350) (4.91 ★), WW → WW, ESCROW, Order. (This item is highlighted with a red box and an arrow pointing to the detailed view on the right).
- PASSWORD MANAGER KIT:** Price: \$0.0001224, Seller: ElCartel (1800) (4.86 ★), WW → WW, ESCROW, Order.

Product Detail View (Right):

PayPal - Scam Page (Phishing site) [Looks Great]

- Seller:** MicroDroper (2350) (4.91 ★) (2,671/3)
- Price:** \$0.00031 (\$4.99)
- Ships to:** Worldwide, Worldwide
- Ships from:** PM
- Escrow:** Yes

Product Description:

Product description

You will get all files for build phishing PayPal site. Look perfect.

We are not include support to the product, so if you have 0% knowledge about site building and php - please do not make an order.

Shipping options

\$0.00 (\$0) You will get download link

Product Reviews

Quantity: 1 **Add to cart**

Product ratings

53d ★★★★★ Enter your comments here

Figure 4. An example of a product listing page on DNM

Data Collection Overview: Carding Shop

News **Cards** Dumps SSN Purchases Checker Wholesale Tickets support offline

Card Type

Information of one card for carders

☐	Bin	Card	Debit/Credit	Mark	Expires	Country	Sate	City	Zip	Phone	VBV	Birthday	Base	Price	Cart
☐	533875	 MASTERCARD BANCA SELLA S.P.A. Dump or cc of this particular bank (BIN) cannot be replaced or refunded.	DEBIT	PREPAID	09/2021	 Italy		Firenze	50134				Republic 	21.6\$	+
☐	548398	 MASTERCARD ING DIRECT N.V. Dump or cc of this particular bank (BIN) cannot be replaced or refunded.	DEBIT	PREPAID	01/2020	 Italy		Cagliari	09124				Seaside 	21.6\$	+
☐	379066	 AMEX TRAVELLERS CHEQUE Dump or cc of this particular bank (BIN) cannot be replaced or refunded.	DEBIT	PREPAID	06/2022	 United Kingdom	QC	Laval	H7V 3R7				Apollo 	21.6\$	+
☐	533317	 MASTERCARD POSTE ITALIANE Dump or cc of this particular bank (BIN) cannot be replaced or refunded.	DEBIT	PREPAID	10/2020	 Italy		Roma	00145				Seaside 	21.6\$	+
☐	533317	 MASTERCARD POSTE ITALIANE Dump or cc of this particular bank (BIN) cannot be replaced or refunded.	DEBIT	PREPAID	09/2020	 Italy		Mialno	20121				Everest 	12\$	+

Figure 5. An example of listing page on carding shop

Data Integration and Visualization

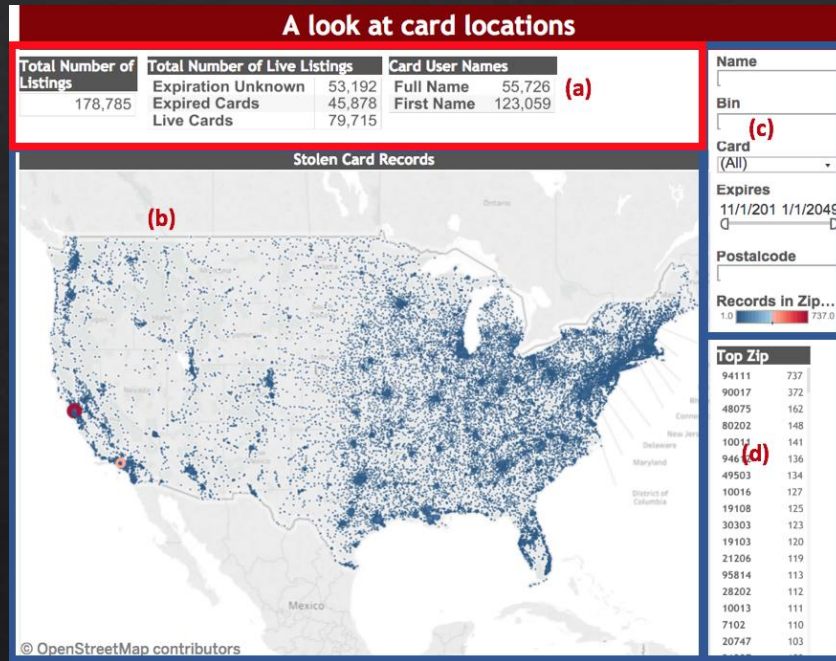


Figure 6. (a) scorecard of active and expired cards, (b) locations, (c) search, sort, and filter functions, and (d) frequency of cards based on zip code

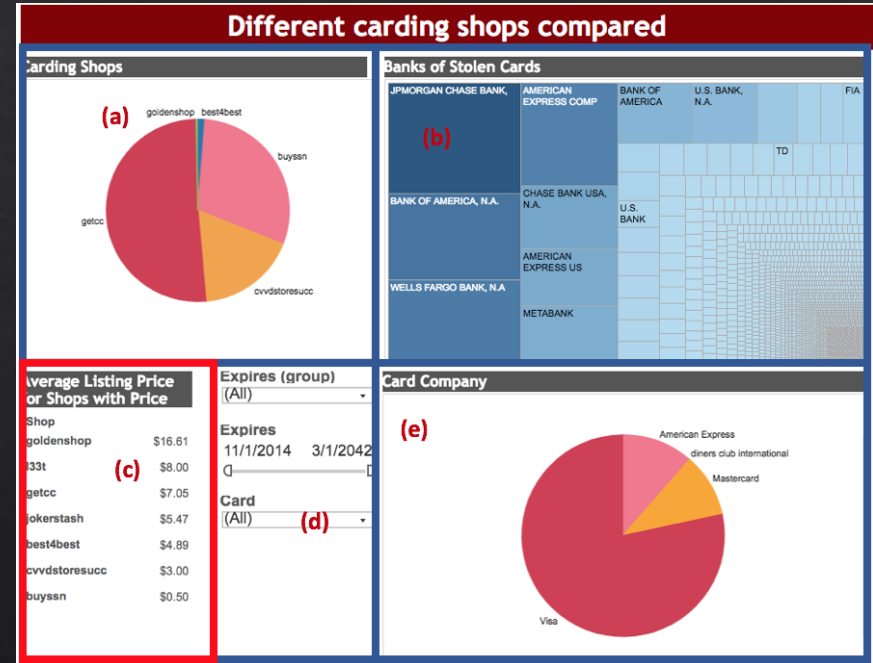
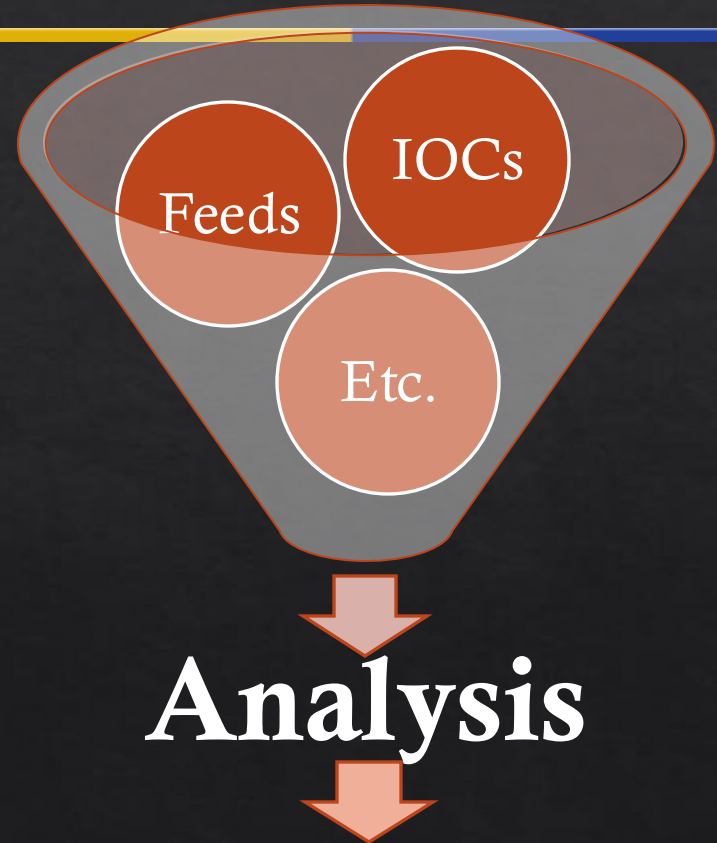


Figure 7. (a) frequency of cards per shop, (b) banks of stolen cards, (c) average card prices, (d) filter capabilities, and (e) card issuers with most stolen cards

Threat Intel Analysis

- ◇ Analysis of:
 - ◇ Internal Intel
 - ◇ Threat Data
 - ◇ External Intel
- ◇ Analysts analyze
- ◇ Automation and analytics can increase effectiveness



What differentiates Threat Intel / Data?

Context (via analysis)

- ◇ Target victim(s)
 - Size
 - Victim type
- ◇ Targeted or Spray
- ◇ Malware
 - Custom or commodity
- ◇ Other orgs
- ◇ Target vertical
- ◇ Tools/Tactics/Procedures
- ◇ Intent of attack
 - Passwords/Credentials
 - Configurations

Remove context and it is just data...

What Threat Intel Does

Situational Awareness

Strategic:

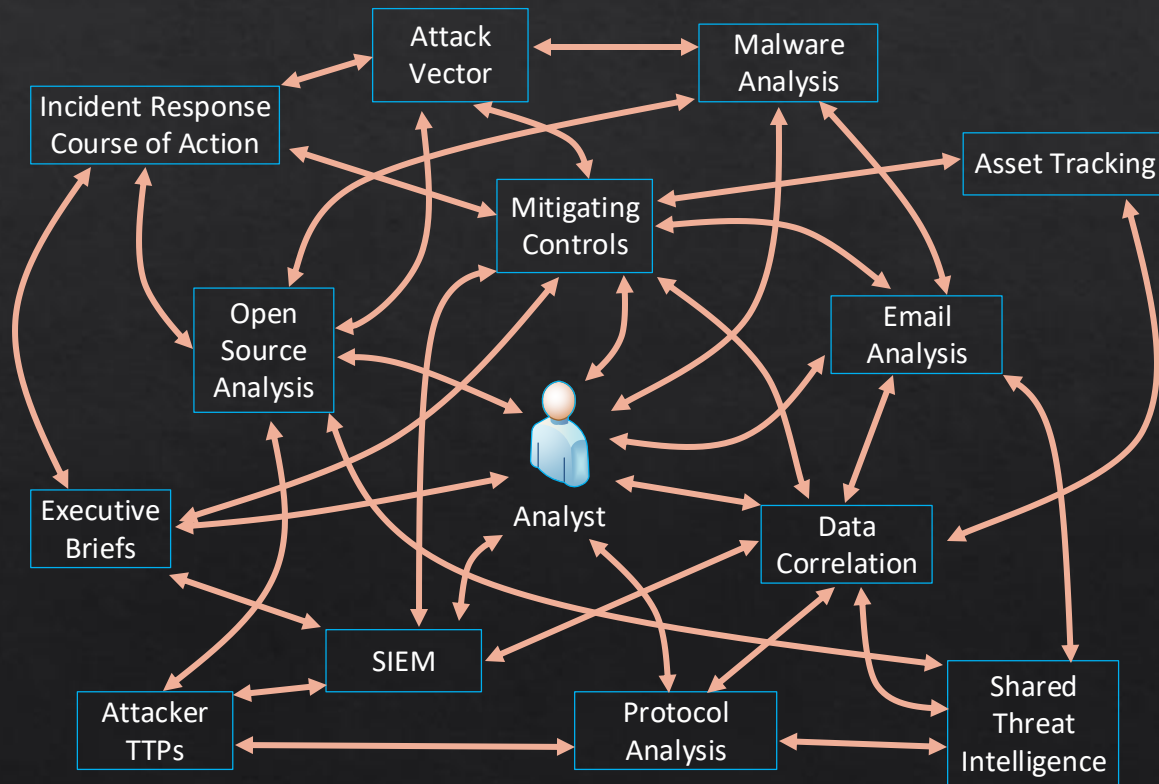
- ◊ Risk Management
- ◊ Vulnerability Management
- ◊ Threat Modeling

Tactical:

- ◊ Proactive/Reactive IR
- ◊ Threat Communications
- ◊ Breach Discovery

Managing Threat Intel

Day in the life...



Threat Intel Platform (TIP)

- ◇ Organization of threat data
- ◇ Contextualize threat data
- ◇ Draw relationships
- ◇ Historical Perspective
- ◇ Automate in parallel with other tools

Threat Intel Platform (TIP)

Open Source:

- CrowdSec Console
- Stixify
- MANTIS
- OpenCTI
- Etc.

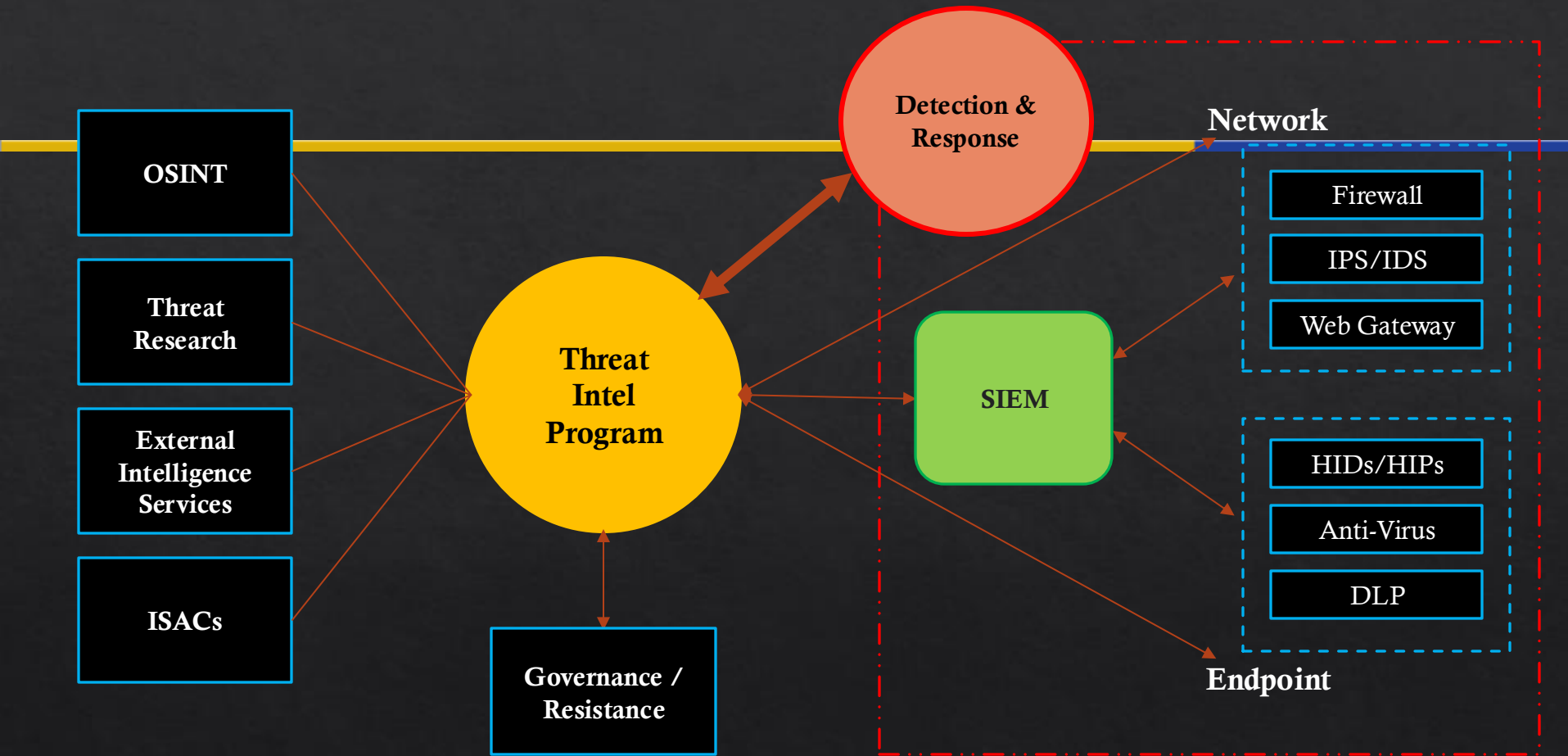
Commercial:

- ThreatConnect
- CrowdStrike
- Splunk
- Etc.

Threat Intel as Component/Program

- ◇ Component of bigger strategy
- ◇ Parallel/Integral to other capabilities
- ◇ Place it properly

Threat Intel could be it's own “Program”



Implementing Threat Intel

- ◇ Define the goals of TI for the organization.
- ◇ Define how you will leverage TI to accomplish those goals.
- ◇ Make it “Actionable”

Actionable Intelligence Analysis

Know your:

Assets

Infrastructure

Personnel

Business operations

Weaknesses/Entry Points

Know:

How to apply threat intel (or not)

Where to apply (capabilities)

How & who to communicate to

Actionable Intelligence Application (Tactical)

- ◇ Apply to Infrastructure:
 - ◇ SIEM/Log Management
 - ◇ Network Security Monitoring
 - ◇ Firewalls
 - ◇ Proxies
 - ◇ Mail Gateways
 - ◇ Training/Communication

Actionable Intelligence Application (Strategic)

- ◇ Apply to security program:
 - ◇ Org Threat Modeling
 - ◇ Risk Management
 - ◇ Security Planning

Integration: Threat Intel & Incident Response

Proactive vs. Reactive IR

- ◇ Hunting for breaches / incidents / anomalies
- ◇ Identifying avenues of attack and addressing
- ◇ Detecting shifts of attack

- Policy
- Risk Management
- Security program design
- Compliance Reporting
- Audit

Ops

- Security reviews
- Identity mgmt
- Security design/reqs
- Vuln Mgmt
- Security Operations

Plan

Resist

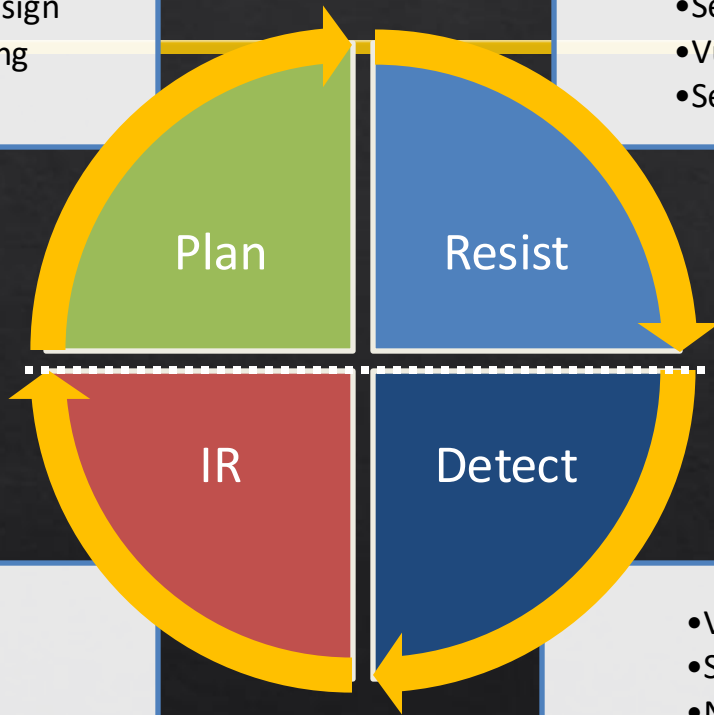
IR

Detect

- Analysis
- Verification
- Containment
- Remediation
- CSIRT

IR

- Visibility
- SIEM/Logs
- Network
- Hosts
- Threat Intel



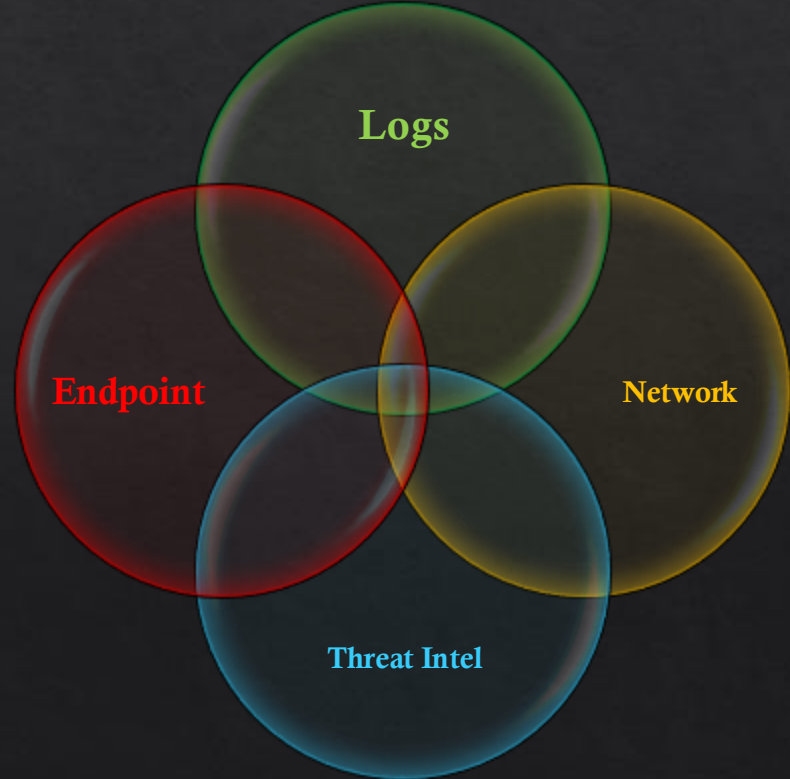
Active Cyber Defense Model



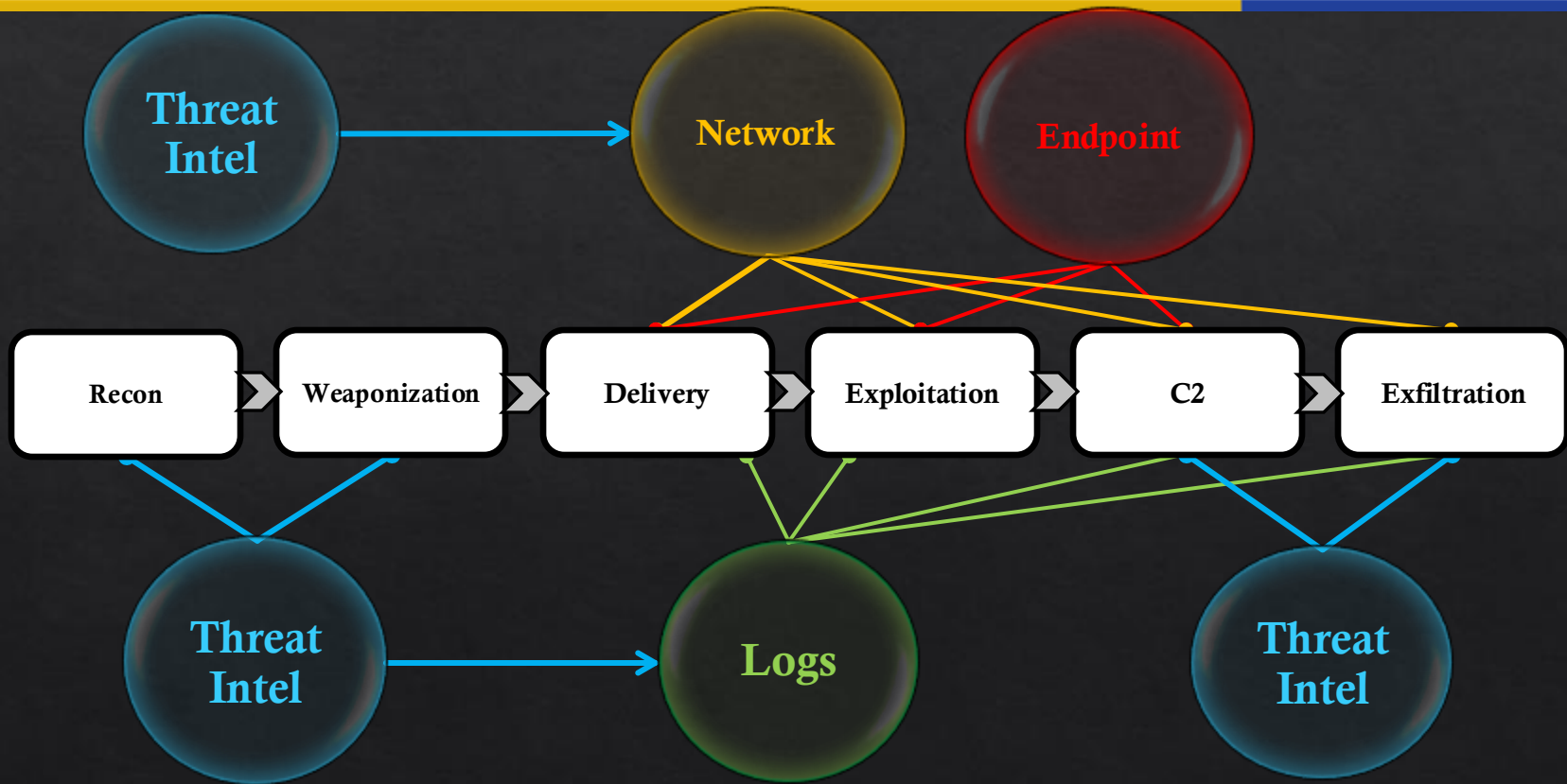
TI/IR Focal Points

Focal points:

- **Logs**
- **Network**
- **Endpoint**
- **Threat Intel**



Kill Chain & Focal Points



Threat Intel Sharing

Advantages of Sharing

- ◇ Benevolence:
 - ◇ Greater Good
- ◇ Self-Interested:
 - ◇ Give some to get some

Scope, Relevancy, Context, Breadth, Capabilities

Ways to share

- ◆ Vertical/Industry sharing groups
 - ◆ ISACs (Ag, IT, Financial, Edu, etc.)
- ◆ Government
 - ◆ US-CERT, FBI Infragard, etc.
- ◆ Org to Org partnerships
- ◆ Vendor(s)

Sharing Strategy

- ◆ Define a sharing strategy (TLP class)
- ◆ Sanitize
- ◆ Targeted sharing
- ◆ No regurgitation (unique data)
- ◆ Ingestible, concise/clear

Conclusion

- ◆ We need to plan ahead of potential attacks, due to attack surface keep changing (e.g., new technology introduced, different user behaviours, etc.) and attacker focus/skill/tools also changing continuously.
- ◆ Threat Intelligence is not just about data, but making sense out of the data you have.
- ◆ Lots of tools out there, understanding how to TI and also what needs TI (prioritise).
- ◆ Don't hide it, share the incident information with relevant people for the benefits of everyone.

Additional readings

- ◇ Pyramid of Pain

- ◇ <https://www.attackiq.com/glossary/pyramid-of-pain/>

- ◇ CTI list

- ◇ <https://github.com/hslatman/awesome-threat-intelligence>